

Sisteme Bazirane na Znanju

Predlog projekta

Sistem za upravljanje IT infrastrukturom i detekciju incidenata

0. Članovi tima:

- Roman Minakov SV83/2023

1. Opis problema

1.1. Motivacija:

Savremena IT infrastruktura postaje sve kompleksnija - organizacije istovremeno upravljaju stotinama servera, servisa i mrežnih uređaja koji generišu ogromne količine logova, metrika i mrežnog saobraćaja. Sigurnosni incidenti poput DDoS napada, kompromitovanih naloga i bočnog kretanja napadača (lateral movement) mogu naneti ogromnu štetu pre nego što ih operateri ručno otkriju. Sa druge strane, problemi sa performansama (preopterećeni serveri, padovi servisa) direktno utiču na dostupnost poslovnih sistema.

Tradicionalna rešenja koja se oslanjaju na statička pravila sa fiksnim pragovima nisu dovoljna: generišu previše lažnih upozorenja (false positives), ne prepoznaju složene obrasce koji se razvijaju kroz vreme, i ne pružaju transparentno obrazloženje zašto je određen incident detektovan. Operaterima je potreban sistem koji reaguje na vremenske obrasce u realnom vremenu, automatizuje određene odbrambene akcije, i pritom pruža jasno obrazloženje svake odluke.

1.2. Pregled problema:

Sistem treba da kontinuirano prati IT infrastrukturu organizacije i donosi odluke o prirodi i ozbiljnosti detektovanih anomalija. Ključni izazovi su:

- Velika količina podataka: servisi šalju metrike na nivou sekundi, logovi se generišu kontinuirano
- Složeni vremenski obrasci: napad se ne može detektovati jednim događajem, već nizom povezanih događaja kroz vreme (CEP)
- Različite kategorije incidenata: sigurnosni incidenti, problemi sa performansama, padovi servisa - svaki zahteva drugačiji prioritet i odgovor
- Potreba za objašnivošću: operater mora razumeti zašto je sistem podigao upozorenje, posebno kada se preduzimaju automatske akcije

Postojeća rešenja poput Splunk, Elastic SIEM i Datadog koriste kombinaciju ML modela i statičkih pravila. ML modeli daju visoku tačnost ali su "crne kutije" bez obrazloženja odluka. Čisto rule-based sistemi su transparentni ali ne prepoznaju složene vremenske obrasce. Naše rešenje kombinuje forward chaining za hijerarhijsku klasifikaciju incidenata, Complex Event Processing (CEP) i accumulate za detekciju vremenskih obrazaca, i backward chaining za dijagnozu uzroka - čime se postiže i tačnost i transparentnost.

1.2.1. Pregled postojećih rešenja i literature:

Splunk Enterprise Security - industrijsko SIEM rešenje koje koristi korelaciona pravila i ML za detekciju pretnji. Nedostatak: pravila su skriptovana u SPL jeziku, nema forward/backward chaining, ograničena transparentnost automatskih odluka. Izvor: splunk.com/en_us/products/enterprise-security.html

Elastic SIEM (Kibana Security) - open-source SIEM nad Elasticsearch stackom. Pruža detekciju na osnovu ML anomaly detection i predefinisanih pravila. Nedostatak: pravila nisu bazirana na znanju, teško proširiva bez tehničkog znanja, bez backward chaining dijagnoze. Izvor: elastic.co/security

Drools CEP za detekciju mreže (Red Hat) - demonstracija korišćenja Drools CEP engine-a za analizu mrežnog saobraćaja. Najsličnija tehnika implementacije našem rešenju, ali ograničena na mrežni sloj bez integracije sa sistemskim metrikama i bez backward chaining dijagnoze. Izvor: developers.redhat.com/blog/2018/07/26/detecting-credit-card-fraud-with-red-hat-decision-manager-7

Prednost našeg rešenja: Industrijska rešenja nisu bazirana na znanju i ne pružaju transparentno obrazloženje odluka. Naš sistem kombinuje četiri nivoa forward chaining-a, CEP i accumulate za složene vremenske obrasce, i backward chaining za rekurzivnu dijagnozu uzroka incidenta - uz potpunu objašnjivost svake automatske akcije.

1.3. Metodologija rešenja:

1.3.1. Ulazi u sistem (input)

Tip ulaza	Opis
Mrežni saobraćaj	Paketi, protokoli, portovi, IP adrese, volumeni
Sistemski logovi	Logovi servera, servisa, OS događaji (syslog, Windows Event Log)
Metriki servisa	CPU, RAM, disk I/O, dostupnost, latencija, error rate
Konfiguracija	Parametri pragova, poznate IP adrese, definisane politike
Korisničke akcije	Broj neuspelih prijava, neobični sati pristupa, akcije na sistemu

1.3.2. Izlazi iz sistema (output)

Tip izlaza	Opis
Alert (upozorenje)	Obaveštenje operatoru sa opisom incidenta i prioritetom (LOW/MEDIUM/HIGH/CRITICAL)
Automatska akcija	Blokiranje IP adrese, gašenje servisa, izolacija hosta

Izveštaj	Agregiran pregled incidenata po vremenskim periodima
Dijagnoza	Obrazloženje koje je pravilo okidač i koji su čvorovi stabla zadovoljeni (backward chaining)

1.3.3. Baza znanja projekta

Baza znanja sadrži pravila grupisana u četiri nivoa, analogno pristupu iz oblasti detekcije prevara, prilagođena IT infrastrukturnom domenu:

- Nivo 1 - Klasifikacija događaja: identifikacija osnovnih anomalija (visoko opterećenje, pad servisa, sumnjiv mrežni saobraćaj, neuspele prijave)
- Nivo 2 - Korelacija događaja: kombinovanje anomalija u složenije incidente (ResourceExhaustion, ActiveAttack, PotentialDDoS)
- Nivo 3 - Vremenski obrasci (accumulate + CEP): detekcija obrazaca koji se razvijaju kroz vreme (brute force, DDoS, lateral movement, cascade failure)
- Nivo 4 - Odluka i odgovor: donošenje finalne odluke o prioritetu incidenta i automatske akcije na osnovu severity score-a

Baza znanja se popunjava iz: konfiguracionih fajlova organizacije (politike, whitelist/blacklist IP adresa, dozvoljeni sati pristupa), ekspertskog znanja tima za sigurnost (definicija normalnog ponašanja, pragovi za svaki servis), i istorijskih podataka o incidentima. Domenski ekspert za projekat biće sertifikovani sistemski administrator sa iskustvom u incident response-u.

1.3.4. Tehnike implementacije

- Forward chaining (4 nivoa ulančavanja): klasifikacija -> korelacija -> vremenski obrasci -> odluka
- Accumulate funkcija: broj neuspelih prijava u vremenskom prozoru, prosečno CPU opterećenje, broj padova servisa, broj različitih izvora napada
- Complex Event Processing (CEP):
- DDoS pattern: TrafficSpike + ServiceDown + HighCPU u roku od 2 minuta
- Compromised account: BruteForceAttempt praćen AnomalousAccess u roku od 5 minuta
- Lateral movement: SuspiciousIP detektovan na 3+ različita servisa za manje od 10 minuta
- Templates: isti šablon pravila za različite servise i hostove sa različitim konfiguracionim parametrima (pragma CPU, RAM, dozvoljene IP adrese)
- Backward chaining: upit "Da li je sistem X trenutno ugrožen?" - rekurzivni query isSystemAtRisk(hostId) koji prolazi stablo zavisnosti incidenata

1.3.5. Backward chaining - rekurzivno stablo zavisnosti

Backward chaining se implementira kroz rekurzivni query nad stablom zavisnosti incidenata. Uvode se dva tipa činjenica:

- IncidentFactor - konkretna činjenica na listu stabla (npr. "host web-server-01 ima visoko CPU opterećenje"). Sadrži polja: id (String), hostId (String), satisfied (boolean).
- IncidentDependency - veza između roditeljskog i dečjeg čvora u stablu (npr. "systemAtRisk zavisi od hasSecurityThreat"). Sadrži polja: parentId (String), childId (String).

1.3.6. Kompletna lista pravila u sistemu:

Nivo 1 - Klasifikacija događaja

Pravilo	Uslov (WHEN)	Akcija (THEN)
R1.1	cpuUsage > 90% for > 5 min	insert(HighCPU)
R1.2	memUsage > 95%	insert(HighMemory)
R1.3	diskUsage > 90%	insert(HighDisk)
R1.4	serviceResponseTime > 3000ms	insert(SlowService)
R1.5	serviceAvailability == DOWN	insert(ServiceDown)
R1.6	failedLoginCount > 5 in 1 min	insert(BruteForceAttempt)
R1.7	sourceIP IN blacklist	insert(SuspiciousIP)
R1.8	networkTrafficVolume > 10x avgBaseline	insert(TrafficSpike)

Nivo 2 - Korelacija događaja

Pravilo	Uslov (WHEN)	Akcija (THEN)
R2.1	HighCPU AND HighMemory	insert(ResourceExhaustion); severity += 20
R2.2	ServiceDown AND HighDisk	insert(StorageIncident); severity += 25
R2.3	BruteForceAttempt AND SuspiciousIP	insert(ActiveAttack); severity += 40
R2.4	SlowService AND TrafficSpike	insert(PotentialDDoS); severity += 30
R2.5	ServiceDown AND NOT ScheduledMaintenance	severity += 35
R2.6	loginHour NOT IN allowedHours AND failedLogins > 0	insert(AnomalousAccess); severity += 20

Nivo 3 - Vremenski obrasci (accumulate + CEP)

Pravilo	Tip	Uslov (WHEN)	Akcija (THEN)
R3.1	accumulate	COUNT(failedLogins) over 10 min > 50	insert(BruteForcePattern); severity += 30

R3.2	accumulate	AVG(cpuUsage) over 30 min > 85%	insert(SustainedHighLoad); severity += 20
R3.3	accumulate	COUNT(ServiceDown) over 5 min > 3	insert(CascadeFailure); severity += 40
R3.4	CEP	TrafficSpike + ServiceDown + HighCPU in 2 min	insert(DDoSPattern); severity += 45
R3.5	CEP	BruteForceAttempt -> AnomalousAccess within 5 min	insert(CompromisedAccount); severity += 50
R3.6	CEP	SuspiciousIP appeared on 3+ different services < 10 min	insert(LateralMovement); severity += 45
R3.7	accumulate	COUNT(DISTINCT srcIP) over 1 min > 500	insert(DistributedAttack); severity += 40

Nivo 4 - Odluka i odgovor

Pravilo	Uslov (WHEN)	Akcija (THEN)
R4.1	DDoSPattern AND CascadeFailure	severity += 20 (bonus)
R4.2	CompromisedAccount AND LateralMovement	severity += 30 (bonus)
R4.3	severity < 30	Alert: LOW; logIncident()
R4.4	severity >= 30 AND severity < 60	Alert: MEDIUM; notifyOnCall()
R4.5	severity >= 60 AND severity < 85	Alert: HIGH; notifyTeam(); blockSuspiciousIP()
R4.6	severity >= 85	Alert: CRITICAL; isolateHost(); notifyManagement(); activateIRP()
R4.7	CompromisedAccount exists	forceLogout(); lockAccount(); notifySecOps()

Backward chaining query-ji

Query	Naziv	Opis
Q1	isSystemAtRisk(X)	Rekurzivni koren - prolazi stablo zavisnosti incidenata

Q2	hasPerformanceDegradation(X)	Provera HighCPU, HighMemory, HighDisk, SlowService
Q3	hasSecurityThreat(X)	Provera BruteForce, SuspiciousIP, LateralMovement, CompromisedAccount
Q4	hasAvailabilityIssue(X)	Provera ServiceDown, CascadeFailure

2. Konkretni primer rezonovanja:

Scenario:

Infrastruktura organizacije: web server (web-01), baza podataka (db-01), i auth servis (auth-01). U periodu od 5 minuta pristižu sledeći događaji:

№	Vreme	Host	Metrika	Vrednost
1	14:00:00	auth-01	failedLogins	55 neuspelih prijava u 10 min
2	14:01:30	web-01	networkTraffic	850 Mbps (baseline: 50 Mbps)
3	14:02:00	web-01	cpuUsage	97%
4	14:02:30	web-01	serviceAvailability	DOWN
5	14:03:00	192.168.1.55	loginAttempt	Uspešna prijava na web-01 (neobičan sat)

Rezonovanje sistema:

Nivo 1 - Klasifikacija:

- Pravilo R1.6: 55 failedLogins u 10 min -> insert(BruteForceAttempt)
- Pravilo R1.8: networkTraffic 850 Mbps >> 10x baseline (500 Mbps) -> insert(TrafficSpike)
- Pravilo R1.1: cpuUsage 97% > 90% for 5 min -> insert(HighCPU)
- Pravilo R1.5: web-01 serviceAvailability == DOWN -> insert(ServiceDown)

Nivo 2 - Korelacija:

- Pravilo R2.4: SlowService AND TrafficSpike -> insert(PotentialDDoS); severity += 30
- Pravilo R2.6: loginHour NOT IN allowedHours AND failedLogins > 0 -> insert(AnomalousAccess); severity += 20

Nivo 3 - CEP i accumulate:

- Pravilo R3.1 (accumulate): COUNT(failedLogins) over 10 min = 55 > 50 -> insert(BruteForcePattern); severity += 30
- Pravilo R3.4 (CEP): TrafficSpike + ServiceDown + HighCPU u roku od 2 minuta -> insert(DDoSPattern); severity += 45
- Pravilo R3.5 (CEP): BruteForceAttempt → AnomalousAccess u roku od 5 minuta -> insert(CompromisedAccount); severity += 50

Nivo 4 - Odluka:

- severity = 30 + 20 + 30 + 45 + 50 = 175 -> CRITICAL
- Pravilo R4.6: Alert CRITICAL; isolateHost(web-01); notifyManagement(); activateIRP()
- Pravilo R4.7: CompromisedAccount -> forceLogout(192.168.1.55); lockAccount(); notifySecOps()

Backward chaining dijagnoza:

Na upit isSystemAtRisk("web-01") sistem prolazi stablo i potvrđuje:

- systemAtRisk <- hasSecurityThreat <- CompromisedAccount (satisfied = true)
- systemAtRisk <- hasAvailabilityIssue <- ServiceDown (satisfied = true)
- systemAtRisk <- hasPerformanceDegradation <- HighCPU (satisfied = true)

Operater dobija potpuno obrazloženje: koji čvorovi stabla su zadovoljeni i koja pravila su ih aktivirala.